

Lab Environment

Start Floci.

```
floci start
```

Load the environment.

```
eval $(floci env)
```

Verify.

```
aws sts get-caller-identity
```

You should see something similar to

```
{
  "Account": "000000000000",
  "Arn": "arn:aws:iam::000000000000:root",
  "UserId": "root"
}
```

Activity 1

Create Your First IAM User

Let's create a developer.

```
aws iam create-user \
  --user-name <your First name>
```

Verify

```
aws iam list-users
```

Expected

```
<your first name>
```

Now inspect it.

```
aws iam get-user \  
  --user-name <your first name>
```

Observe

- ARN
- UserName
- CreateDate

Activity 2

Create Multiple Users

Create several users.

```
aws iam create-user --user-name <president>  
  
aws iam create-user --user-name <HOD>  
  
aws iam create-user --user-name <PL>
```

List again.

None have permissions yet.

Activity 3

Can They Access S3?

Create an S3 bucket.

```
aws s3 mb s3://college-data
```

Now ask yourself:

Can President access it?

Answer:

No.

Because we haven't attached any policy.

Activity 4

Create Your First Policy

Create a file

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": [
        "s3:ListBucket"
      ],
      "Resource": "*"
    }
  ]
}
```

Save as

```
listbucket.json
```

Create policy

```
aws iam create-policy \
  --policy-name ListBucketPolicy \
  --policy-document file://listbucket.json
```

List policies

```
aws iam list-policies
```

Understand the Policy

Effect

Means

Allow

Action

s3:ListBucket

Resource

*

Meaning

Can list every bucket.

Activity 5

Attach Policy

Attach it.

```
aws iam attach-user-policy \  
  --user-name President \  
  --policy-arn arn:aws:iam::000000000000:policy/ListBucketPolicy
```

Now inspect.

```
aws iam list-attached-user-policies \  
  --user-name developer
```

Activity 6

Inline Policy

Instead of a managed policy, create an inline policy.

```
aws iam put-user-policy \  
  --user-name HOD \  
  --policy-name ReadOnly \  
  --policy-document file://listbucket.json
```

Inspect.

```
aws iam list-user-policies \  
  --user-name intern
```

Question:

What's the difference between Managed Policy and Inline Policy?

Activity 7

Create Groups

Create

Developers

```
aws iam create-group \  
  --group-name Developers
```

Add users.

```
aws iam add-user-to-group \  
  --group-name Developers \  
  --user-name <user-name>
```

Also

```
aws iam add-user-to-group \  
  --group-name Developers \  
  --user-name Penjo
```

List members.

```
aws iam get-group \  
  --group-name Developers
```

Now attach policy to group.

```
aws iam attach-group-policy
```

Activity 8

Explicit Deny

This is the most important IAM concept.

Create

```
{  
  "Version": "2012-10-17",  
  "Statement": [  
    {  
      "Effect": "Deny",  
      "Action": "s3:*",  
      "Resource": "*"   
    }  
  ]  
}
```

Attach it.

Observe

Even if another policy says

```
Allow
```

the request is denied.

Remember:

```
Explicit Deny
    ↑
Overrides
    ↑
Everything
```

Activity 9

Create a Role

Roles are identities that are assumed temporarily.

Create

```
EC2Role
```

You'll also define a trust policy, for example:

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Principal": {
        "Service": "ec2.amazonaws.com"
      },
      "Action": "sts:AssumeRole"
    }
  ]
}
```

Create it.

```
aws iam create-role \
  --role-name EC2Role \
  --assume-role-policy-document file://trust.json
```

Activity 10

Assume Role

```
aws sts assume-role
```

Observe

Temporary

- Access Key
- Secret Key
- Session Token

This is how

- Lambda
- EC2
- ECS
- EKS
- CloudShell

obtain temporary credentials.

Activity 11

Permission Evaluation

Create

User

↓

Group

↓

Managed Policy

↓

Inline Policy

↓

Resource Policy

↓

Explicit Deny

Case 1 — HR Department

Create:

- Users: **Nima, Dawa**
- Group: **HR**
- Bucket: **employee-records**

Goal:

- Only HR members can list and access the bucket.
 - Others should receive **AccessDenied**.
-

Case 2 — Developer

Developer can:

- Read from S3
 - Upload to one bucket only
 - Cannot delete objects
-

Case 3 — Auditor

Can:

- List all IAM users
- List all policies
- Read bucket metadata

Cannot:

- Modify anything
-

Case 4 — Administrator

Full access except:

- Cannot delete IAM users